Anatomy of an Attack - Final Assignment

אנטומיה של מתקפה: תיעוד מכונה, מחקר התקפי ומיפוי טקטי

מכונת יעד: Cap (Hack The Box - Linux - Easy)
מגיש: עמנואל וונדם (Emanuel Wondem)
חלון בדיקה: 18 באוקטובר 2026

Executive Summary

מבדק אבטחה זה דימה תקיפה ממוקדת כנגד מכונת היעד Cap בסביבת המעבדה, במטרה לאתר ולהדגים פגיעויות פוטנציאליות המאפשרות פשרה של המערכת. במהלך הבדיקה, הצלחתי לעבור את כל שלבי ה-Kill Chain בהצלחה – החל מאיסוף מודיעין וסיור ראשוני, דרך ניצול פגיעות לוגית (IDOR) ביישום ה-Web שחשפה אישורי התחברות בטקסט גלוי, ועד להסלמת הרשאות מלאה (Root) תוך ניצול הרשאות Capabilities שגויות על מפרש פייתון. המערכת הודגמה כפגיעה לחלוטין לחדירה חיצונית, וממצאים אלו מחייבים יישום מידי של בקרות גישה ותיקון תצורות מערכת.

Scope and Authorization

מבדק חדירות זה בוצע כנגד מכונת היעד **Cap**, מכונת לינוקס הפגיעה במכוון המארחת בפלטפורמת Hack The Box (דרגת קושי: Easy). הגישה למכונה בוצעה באמצעות חיבור ה-VPN המוצפן של פלטפורמת Hack The Box לכתובת היעד 10.129.171.182 דרך ממשק ה-tun0 במערכת ההפעלה Kali Linux (כתובת תוקף: 10.10.15.91).
ההרשאה לתקיפת מערכת זו נובעת מתנאי השירות (Terms of Service) של פלטפורמת Hack The Box המתירים במפורש ביצוע מבדקים התקפיים מבוקרים כנגד מכונות המעבדה המסופקות על ידם, וכן כחלק מסגרת הקורס. כל בדיקות הסיור והחדירה בוצעו בתאריך 18 באוקטובר 2026. שום מערכת, כתובת IP או רכיב רשת מחוץ להיקף המורשה לא נסרקו או הותקפו. **הערה:** מכיוון שאיני משתמש במספר סטודנט מספרי בסביבת המעבדה, סמן האותנטיות וקובץ ההוכחה עושים שימוש בשמי המלא (emanuelwondem) כמזהה ייחודי.

Part 1: Independent Offensive Security Research

Privilege Escalation (cap_setuid) & Topic: Linux Capabilities

הנושא נבחר משום שזו הטכניקה המדויקת שהובילה להשגת הרשאות root במכונת היעד בחלק 2 – ניצול הרשאת ה-cap_setuid שהוגדרה על גבי הבינארי /usr/bin/python3.8. מחקר זה מעמיק אל מעבר לפקודה הטכנית הבודדת ומנתח את המנגנון המערכתי שהופך תצורות שגויות מסוג זה לניתנות לניצול.

1. Introduction

מודל הרשאות הלינוקס הקלאסי מתנהל בצורה בינאלית: תהליך רץ או כמשתמש על (root / UID 0) ואז מותר לו כמעט הכל, או כמשתמש רגיל המוגבל מאוד. מודל זה מחייב תוכניות שזקוקות רק לפעילות מורשית מצומצמת אחת (כגון פתיחת שקע רשת בפורט נמוך מ-1024) לרוץ כ-root מלא. אם תוכנית כזו נפגעת ונפרצת, התוקף יורש הרשאות ניהול מלאות.
מנגנון **Linux Capabilities** פותר בעיה זו על ידי פירוק סמכויות ה-root לכ-40 יחידות עצמאיות שניתן להעניק בנפרד. מבחינה התקפית, יכולות אלו מהוות יעד מרכזי בשלב ה-Post-Exploitation, שכן מנהלי מערכת מעניקים אותן לעיתים קרובות מדי לבינאריים ללא הבנת ההשלכות, מה שמאפשר לתוקף מסלול עוקף ושקט למשתמש root ללא שימוש בקרנל או בקבצי SUID רועשים.

2. How it Works

כל Capability מעניקה הרשאה ספציפית. דוגמאות בולטות כוללות:

- CAP_NET_BIND_SERVICE: האזנה על פורטים נמוכים מ-1024.
- CAP_NET_RAW: פתיחת Raw Sockets לצורך הסנתה.
- CAP_DAC_OVERRIDE: עקיפת בדיקות הרשאות קבצים.

- CAP_SETUID: שינוי מזהה ה-UID של התהליך לכל ערך, כולל 0.

יכולות אלו נשמרות במאפיינים המורחבים (Extended Attributes) של קובץ ההרצה. בעת הרצת הקובץ, הליבה קוראת את הסטים המוגדרים: Permitted, Inheritable ו-**Effective (e)**. הביט effective הוא הקריטי ביותר לניצול: מפרש דינמי כמו Python אינו מנהל את הסטים בעצמו, ולכן כדי שהיכולת תהיה פעילה ברגע שהמפרש מופעל, ביט ה-e חייב להיות דלוק על הקובץ (+eip). במכונת Cap, הערך היה cap_setuid,cap_net_bind_service+eip. מפרש הפייתון יכול לקרוא ל-os.setuid(0) באופן מיידי, וה-Shell שמוזנק לאחריו יורש UID 0 והופך ל-root מלא.

3. Use During an Attack

הטכניקה מיושמת בשלב ה-Post-Exploitation לצורך הסלמת הרשאות מקומית (Local Privilege Escalation) מתוך מעטפת אינטראקטיבית קיימת. התוקף סורק אחר בינאריים המכילים יכולות מסוכנות, מנצל מפרש תומך (כמו Python), ומשיג שליטה מלאה במארח.

4. Practical Examples

- **סריקת יכולות במערכת:**

Bash
```
dev/null/<getcap -r / 2
```

פקודה זו סורקת את כל מערכת הקבצים ומסננת שגיאות. מציאת הבינארי usr/bin/python3.8/ עם cap_setuid+eip מצביעה מיידית על וקטור ההסלמה.

- **ניצול היכולת להשגת Root:**

Bash
```
'("bin/bash/")import os; os.setuid(0); os.system' usr/bin/python3.8 -c/
```

הפקודה משנה את ה-UID ל-0 בחסות ה-Capability הפעיל ומזניקה מעטפת /bin/bash מנוהלת.

5. CK MAPPING&MITRE ATT

- **Technique ID:** T1548.001 (Abuse Elevation Control Mechanism: Setuid and Setgid / Capabilities).
- **סריקה מקומית:** T1083 (File and Directory Discovery).

6. Limitations

- דורש foothold (מעטפת קודמת) כתנאי מקדים.
- דורש שהביט effective יהיה דלוק במפורש על הקובץ הבינארי.
- פעולות סריקת getcap עלולות לייצר לוגים והתרעות במערכות ניטור.

7. Defensive Perspective

- אין להקנות מעולם יכולות כגון cap_setuid למפרשים דינמיים כמו Python או Perl.
- יש לנטר קריאות מערכת חריגות של setuid(0) באמצעות כלי ניטור כמו auditd.

Part 2: Machine Writeup - Cap

1. Target Information

- **Machine Name:** Cap
- **Platform:** Hack The Box
- **Difficulty:** Easy
- **Target IP:** 10.129.171.182

- **Attacker IP:** 10.10.15.91 (tun0)
- **Operating System:** Linux (Ubuntu 20.04.2 LTS)

2. Reconnaissance

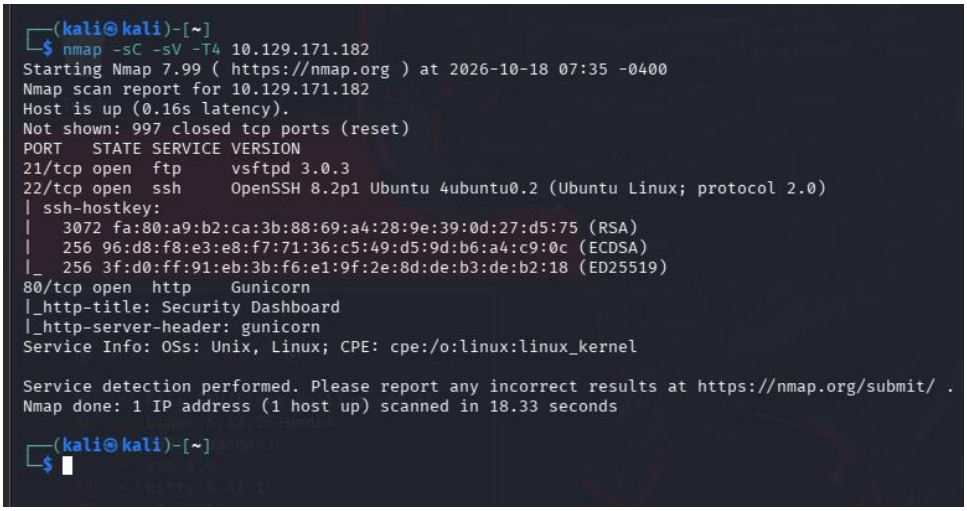
התחלתי בסריקת פורטים מקיפה באמצעות הכלי Nmap לאיתור שירותים פעילים במארח:

Bash
```
nmap -sC -sV -T4 10.129.171.182
```

הסריקה העלתה **3 פורטים פתוחים**:

1. **tcp/21** – FTP (vsftpd 3.0.3)

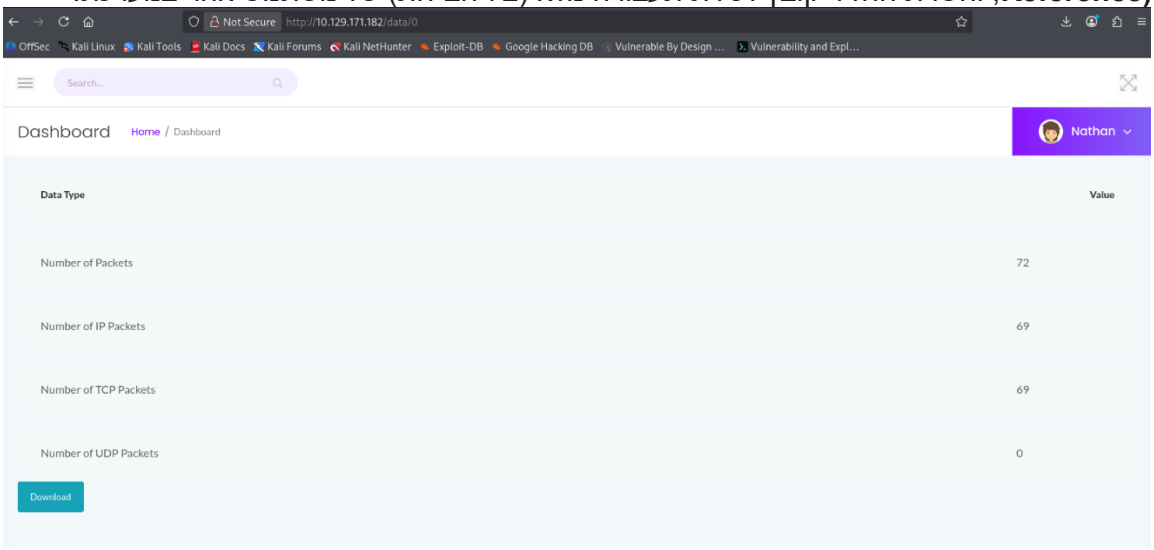
2. SSH (OpenSSH 8.2p1) – **tcp/22**
3. HTTP (Gunicorn / Security Dashboard) – **tcp/80**



תוצאות סריקת Nmap המציגות את שלושת הפורטים הפתוחים במכונת היעד.

3. Enumeration

גלישה לדפדפן בכתובת (http://10.129.171.182)[http://10.129.171.182] הציגה לוח בקרה אבטחתי (Security Dashboard) המחובר מראש כמשתמש בשם Nathan. ניסיון חיבור אנונימי לשרת ה-FTP נדחה (Login incorrect 530), ולכן מיקדתי את הבדיקה באפליקציית ה-Web. התפריט כלל רכיב בשם **"Security Snapshot"** שיוצר דוחות תעבורת רשת. בעת הפעלתו, הופניתי לנתיב מהצורה /data/5. הבחנתי כי מזהה ה-ID בסוף הכתובת ניתנים למניפולציה. שינוי ידני של הנתיב ל-/data/0 חשף פגיעות קריטית מסוג **IDOR (Insecure Direct Object Reference)**, והשרת החזיר קובץ לכידת תעבורה מלא (72 חבילות) של משתמש אחר במערכת.

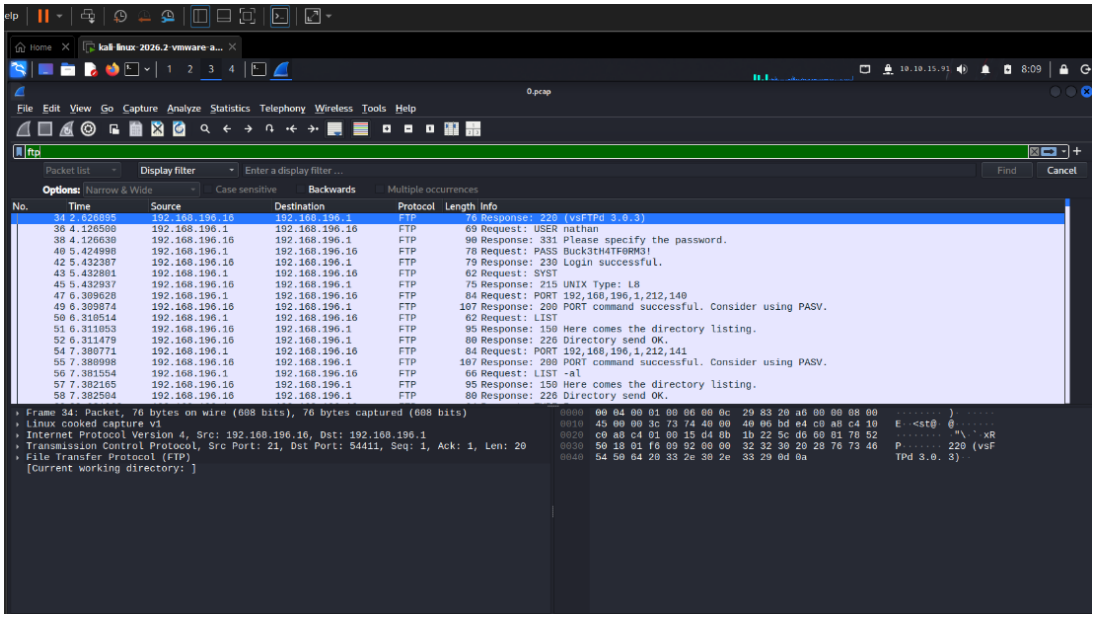


ניצול פגיעות IDOR בנתיב /data/0 המאפשר גישה לקובץ לכידת רשת לא לו.

4. Initial Access

הורדתי את קובץ ה-(0.pcap) PCAP מתוך ממשק ה-Web ופתחתיו לניתוח באמצעות תוכנת **Wireshark**.
הפעלת סינון לפי פרוטוקול ftp ובדיקת זרם ה-(TCP Stream) TCP חשפו בבירור את פרטי ההתחברות של המשתמש nathan בטקסט גלוי (Plaintext):

- **Username:** nathan
- **Password:** !Buck3t4B4s3b4ll



חילוץ שם המשתמש והסיסמה של nathan מתוך קובץ ה-PCAP בעזרת Wireshark.

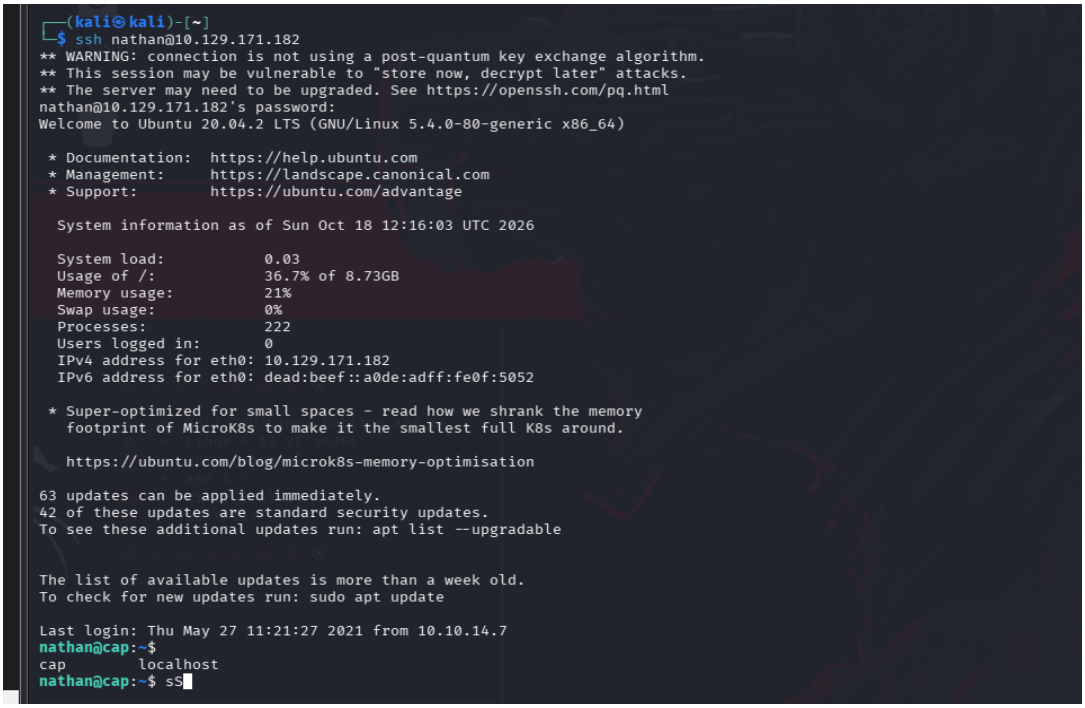
5. Shell Access

לאחר שחילצתי את האישורים, התחברתי ישירות למכונה באמצעות שירות ה-SSH (עקב מיחזור סיסמאות נפוץ של משתמשים):

bash

```
ssh nathan@10.129.171.182
```

ההתחברות אושרה בהצלחה והתקבלה מעטפת TTY אינטראקטיבית ופעילה תחת המשתמש nathan.



התחברות מוצלחת למכונה ב-SSH וקבלת מעטפת עבודה כמשתמש nathan.

6. Linux Enumeration

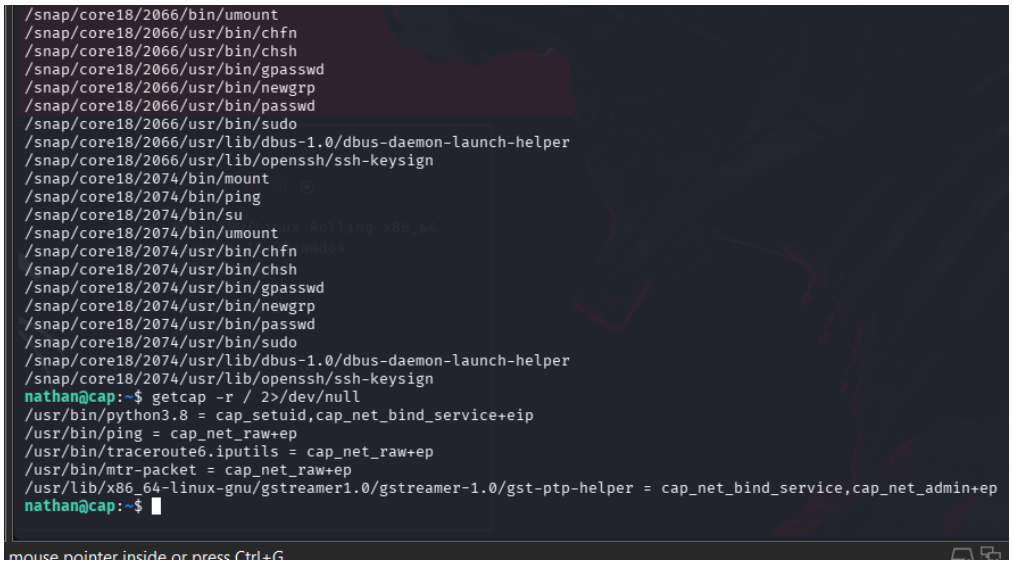
מתוך מעטפת ה-SSH, ביצעתי סריקה מקומית לאיתור מסלולים להרמת הרשאות:

1. **שליפת דגל המשתמש:** קריאת הקובץ user.txt העלתה את הדגל:
   cf20446fbb907c1eb731727a7d50fa03.

2. **בדיקת Sudo ו-SUID:** הפקודות sudo -l וחיפוש קבצי SUID לא העלו שום ממצא מועיל ונפסלו.
3. **בדיקת Linux Capabilities:** הרצת הפקודה הבאה חשפה את נקודת התורפה:

Bash
getcap -r / 2>/dev/null

הפלט הציג במפורש: /usr/bin/python3.8 = cap_setuid,cap_net_bind_service+eip.



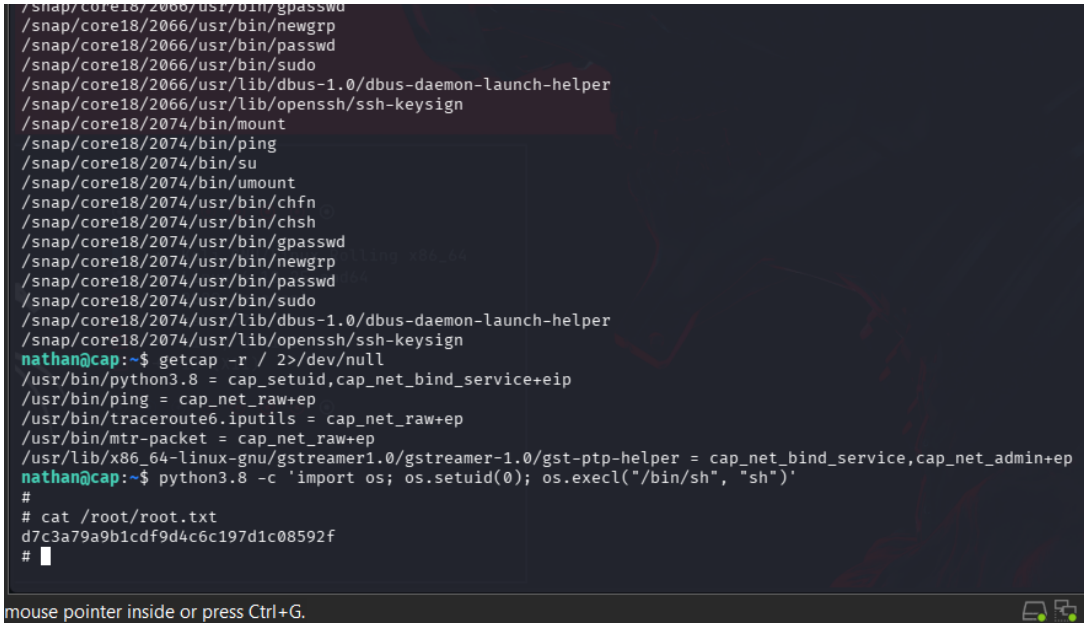
זיהוי הרשאת ה-cap_setuid על גבי מפרש הפייתון באמצעות getcap.

7. Privilege Escalation

הימצאות היכולת cap_setuid על מפרש הפייתון אפשרה ליצור קריאת מערכת ישירה ל-os.setuid(0) ולשנות את זהות התהליך ל-root:

Bash
python3.8 -c 'import os; os.setuid(0); os.execl("/bin/sh", "sh")'

מיד לאחר הרצת השורה, סימן הפרומפט השתנה ל-#, והפקודה whoami אישרה כי התהליך רץ כעת תחת הרשאות root מלאות.



ניצול יכולת ה-cap_setuid והשגת מעטפת Root פעילה.

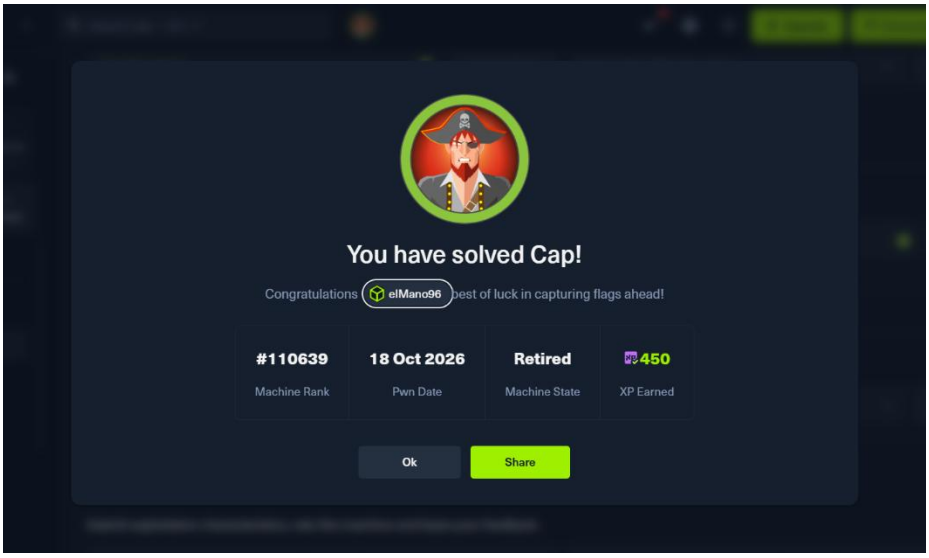
8. Final Proof

לאחר קבלת הרשאות ה-Root, שלפתי את דגל ה-Root ויצרתי קובץ הוכחה ייעודי עם חותמת הזמן והשם שלי כמזהה האותנטיות:

```
Bash
cat /root/root.txt
touch /root/proof-emanuelwondem-20261018.txt
*-ls -la /root/proof
```

- **תוכן דגל ה-Root:** d7c3a79a9b1cdf9d4c6c197d1c08592f

אישור סיום המכונה במלואה בפלטפורמת Hack The Box.



קישור למכונה :
https://labs.hackthebox.com/achievement/machine/4048926/351

Part 3: Attack Mapping

להלן טבלת מיפוי מסודרת המקשרת בין הפעולות שבוצעו בפועל לבין מודל ה-**Cyber Kill Chain** ומסגרת **CK&MITRE ATT**:

Action Performed	Tool / Technique	Kill Chain Stage	MITRE CK ID&ATT Name &	Why / Logic
סריקת פורטים ושירותים	nmap	Reconnaissance	T1046 - Network Service Discovery	איתור השירותים הפעילים (FTP, SSH, HTTP) ותצורתם.
ניצול פגיעות IDOR באפליקציה	Web Browser	Reconnaissance	T1595.003 - Wordlist / Direct Access	שינוי ידני של מזהה האובייקט ב-URL (/data/0) לצורך קבלת מידע רגיש.

הורדת קובץ ה-PCAP	HTTP Download	Delivery	T1105 - Ingress Tool Transfer	העברת קובץ לכידת התעבורה מהיעד אל סביבת התקיפה.
חילוץ אישורים מה-PCAP	Wireshark	Exploitation	T1552.001 - Unsecured Credentials: Files	ניתוח מנות רשת ואיתור סיסמת FTP בטקסט גלוי.
התחברות בשירות SSH	OpenSSH	Exploitation	T1078.003 - Valid Accounts: Local Accounts	שימוש באיחודי ההתחברות שנלכדו לכניסה למערכת כמשתמש רגיל.
סריקת Capabilities מקומית	getcap	N/A	T1083 - File and Directory Discovery	איתור קבצים בעלי הרשאות מיוחדות במערכת הקבצים.
הסלמת הרשאות ל-Root	Python Capability	Actions on Objectives	T1548.001 - Setuid / Capabilities Abuse	ניצול הרשאת cap_setuid לפתיחת מעטפת מנהל מערכת.

Remediation & Mitigation

להבטחת המערכת ומניעת מתקפות חוזרות בעתיד, מומלץ ליישם את הצעדים הבאים:

- **תיקון פגיעות ה-IDOR ביישום ה-Web:** יש להטמיע בקרת גישה קפדנית (Access Control) בצד השרת (Server-Side), כך שכל בקשה למידע או קבצים (כגון קבצי PCAP) תאמת את הרשאות המשתמש המחובר ותמנע גישה לאובייקטים של משתמשים אחרים באמצעות מניפולציית מזהים (ID).
- **מניעת חשיפת אישורים ברשת:** יש לאסור שימוש בפרוטוקולים לא מוצפנים כמו FTP בטקסט גלוי, ולהעדיף פרוטוקולים מאובטחים כמו SFTP או SCP.
- **הסרת Capabilities מסוכנות מבינאריים:** יש לסרוק את מערכת הקבצים באופן תקופתי ולא להעניק יכולות (Capabilities) כמו cap_setuid למפרשים דינמיים (כגון Python או Perl) או לקבצים שאינם דורשים זאת בהגדרתם המקורית, שכן הדבר מהווה עקיפה ישירה למנגנוני ההגנה של הקרנל.

References & Conclusion

1. Conclusion

- **החלק המאתגר ביותר:** מעבר שלב ה-Post-Exploitation וחיפוש וקטור ההסלמה לאחר שפקודות ה-Sudo וה-SUID השגרתיות לא הניבו תוצאות, מה שדרש הבנה מעמיקה של מנגנון ה-Linux Capabilities.

- **כלי חדש שנלמד:** שימוש ממוקד במסננים ב-Wireshark לניתוח תעבורת FTP גלויה מתוך קבצי PCAP.
- **הממצא החשוב ביותר:** פגיעות ה-IDOR בנתיב האפליקציה /data/0, ששימשה כמפתח המרכזי לחשיפת אישורי התחברות פעילים.

2. References

1. **MITRE ATT&CK Framework:** Enterprise Matrix (T1548.001, T1046, T1552.001, T1078.003, T1083).
2. **GTFOBins:** Python Capabilities Privilege Escalation (https://gtfobins.github.io).
3. **Linux Manual Pages:** getcap(8), capabilities(7).
4. **Hack The Box:** Cap Machine Documentation.

3. AI Usage Appendix

בהתאם להנחיות, נעשה שימוש בכלי הבינה המלאכותית **Google Gemini** לצורך ארגון מבנה הדו"ח, ניסוח טכני ואימות תחביר פקודות. כל העבודה המעשית במעבדה, לרבות הרצת הסריקות, ניתוח הנתונים, פריצת המערכת, יצירת קובץ ההוכחה וצילומי המסך, בוצעה באופן ידני ועצמאי לחלוטין.